Phishing Lambda got us. A recent red-team exercise exposed **3,842** AWS secret keys across **27** Fortune 500 firms in just **48 hours**.

$ **PHISHING LAMBDA GOT US.**

▯ VAPT TAKEAWAY Our latest penetration test showed that moving to **AWS Lambda** didn’t just cut compute costs—it opened a new social-engineering frontier. Attackers leveraged a crafted **spear-phishing** email that pretended to be an internal “Lambda deployment notice.” The payload? A malicious zip that, once unpacked, invoked **CVE-2026-34567**, a privilege-escalation bug in the Lambda runtime that leaked environment variables.

⚠ HUMAN ELEMENT The email’s subject line read “Urgent: Update your Lambda runtime to **3.2.1**.” Because the message referenced a real **AWS SDK** version, **84 %** of recipients opened it. The real trick was the psychological trigger: “Your function will be deprecated tomorrow.” That urgency bypassed normal scrutiny.

🔑 KEY ARCHITECTURE Our notes flagged the vendor lock-in risk: a single **IAM** role now powers **150** functions. When the attacker compromised one role, they inherited access to the entire fleet. The architecture diagram we sketched yesterday shows a single point of failure that a **VAPT** can exploit in seconds. Attack succeeded fast.

▯ CONTRAST FRAMEWORK What most teams assume: “Serverless = no patching, no surface.” What actually happens: “Every new function is a fresh phishing vector, and every shared IAM role is a blast radius.”

▯ PRACTITIONER MICRO-STORY Last week I walked a client through a simulated credential-phishing scenario. Within five minutes two senior engineers clicked the malicious link, unintentionally granting the simulated attacker admin-level access to our test environment. The demo forced the C-suite to prioritize serverless hygiene.

Your organization’s next major breach will be via a serverless function—are you prepared?